



Cloud Security Posture Management

Runbook – Remediation

Access keys should be rotated every 90 days

Control ID	IAM-007
Control Name	Access keys should be rotated every 90 days
Severity	Medium
Audience	Application Teams · Cloud Platform · Cloud Security
Tooling	Wiz Cloud Security Platform
Compliance	CSA CCM v4.0.5 → IAM-02 (Access Control)
Version	1.0
Owner	Cloud Security Team
Last Updated	May 2026
Review Cycle	Quarterly

Table of Contents

Table of Contents.....

1. Overview

2. Description

3. Objective

4. Triage Process.....

4.1 Identify Affected Resources (Wiz)

4.2 Categorize Users

5. Manual Mitigation – AWS Console.....

5.1 Safe Key Rotation Sequence.....

6. Mitigation – AWS CLI.....

Step 1 — List existing access keys.....

Step 2 — Create new access key

Step 3 — Deactivate old key (after updating all consumers)

Step 4 — Check CloudTrail for remaining usage of old key.....

Step 5 — Delete old key (after validation period)

Step 6 — Verify inactivity independently (optional)	6
7. Mitigation Using Terraform (IaC)	6
7.1 Automatic Key Rotation Using Terraform	6
7.2 Recommended Terraform Workflow	7
8. Mitigation Using CloudFormation (IaC)	7
8.1 Option 1 — Replace Access Keys with IAM Roles (Preferred)	7
8.2 Option 2 — Rotate via Secrets Manager	8
8.3 Recommended CloudFormation Workflow	8
9. Document Exception	9
10. Detective Control	9
10.1 Credential Report — Key Columns	9
10.2 Generate Credential Report (AWS Console)	9
10.3 Enable AWS Config Rule	10
11. Validation and Success Criteria	10
12. References	10

1. Overview

Detection Tool	Wiz Cloud Security Platform
Wiz Rule	Cloud Configuration Rules Wiz
Detective Control	AWS IAM Credential Reports (AccessKey1LastRotated / AccessKey2LastRotated) · AWS Config — access-keys-rotated

2. Description

This control identifies IAM access keys that have not been rotated within the last 90 days. Long-lived access keys increase the window of opportunity if credentials are compromised, leaked, or shared — even if the key appears to be in active use. Regular rotation limits the exposure period of any single credential.

 Best practice: Prefer IAM roles over long-lived access keys wherever possible. Access keys should only exist where programmatic access via roles is not feasible (e.g. on-premises systems or third-party integrations).

3. Objective

This runbook provides standardized operational guidance for security and cloud operations teams to:

- Validate stale access key findings in Wiz
- Identify all consumers of each affected key before rotating
- Safely rotate IAM access keys without causing service disruption
- Handle approved exceptions with documented compensating controls

4. Triage Process

 **General triage principles** — including how to assess whether a finding is valid, a false positive, or an accepted risk — are defined in the [Master Template – Remediation SOP](#). Complete that review before proceeding with the control-specific steps below.

4.1 Identify Affected Resources (Wiz)

Navigate to Wiz → Cloud Configuration Findings and filter by the rule: "Access keys should be rotated every 90 days". Export the list of affected resources.

Collect the following details for each finding:

- IAM username and AWS account ID
- Access key ID
- AccessKey1LastRotated / AccessKey2LastRotated dates from the credential report

- Key status (Active / Inactive)

Generate a fresh credential report to confirm rotation dates:

```
aws iam generate-credential-report
aws iam get-credential-report --query Content --output text | base64 --decode >
credential_report.csv
```

4.2 Categorize Users

Category	Applies to	Next Action
A – Exception	Key rotation delay approved · documented break-glass usage	→ Proceed to Section 9 (Exception Process). Document compensating controls.
B – Rotate	Active keys older than 90 days with no exception	→ Follow safe rotation sequence — Section 5.
C – Disable	Inactive keys with no rotation evidence and no active use	→ Disable and schedule for deletion — see IAM-047 runbook.

⚠ Critical: Before rotating any key, identify all applications and services using that key. Rotating without updating consumers will cause outages. Check CloudTrail for recent usage before proceeding.

5. Manual Mitigation – AWS Console

Use this approach for one-off remediations or when the IAM user is not managed by IaC.

5.1 Safe Key Rotation Sequence

Follow this sequence precisely to avoid service disruption:

Step	Action	Detail
1	Create new access key	IAM → Users → [user] → Security credentials → Create access key. Maximum 2 keys per user.
2	Update all consumers	Update every application, CI/CD pipeline, and service that uses the old key with the new key.
3	Verify new key works	Monitor CloudTrail for successful API calls using the new key before proceeding.
4	Deactivate old key	Set the old key to Inactive. Do NOT delete yet — this allows rollback if needed.

5	Monitor 7–14 days	Confirm no service disruption. Check CloudTrail for any remaining usage of the old key.
6	Delete old key	After the validation period, delete the old key from IAM.

6. Mitigation – AWS CLI

Run the following commands in sequence. Ensure you have the necessary IAM permissions before proceeding.

Step 1 — List existing access keys

```
aws iam list-access-keys --user-name <USERNAME>
```

Step 2 — Create new access key

```
aws iam create-access-key --user-name <USERNAME>
# Store the output securely – SecretAccessKey is only shown once
```

Step 3 — Deactivate old key (after updating all consumers)

```
aws iam update-access-key \
  --user-name <USERNAME> \
  --access-key-id <OLD_KEY_ID> \
  --status Inactive
```

Step 4 — Check CloudTrail for remaining usage of old key

```
aws cloudtrail lookup-events \
  --lookup-attributes AttributeKey=Username,AttributeValue=<USERNAME> \
  --start-time $(date -d '7 days ago' -Iseconds) \
  --query 'Events[?contains(CloudTrailEvent, `<OLD_KEY_ID>`)]' \
  --output table
```

Step 5 — Delete old key (after validation period)

```
aws iam delete-access-key \
```

```
--user-name <USERNAME> \  
--access-key-id <OLD_KEY_ID>
```

Step 6 — Verify inactivity independently (optional)

Generate and download the IAM credential report to confirm the new key's creation date:

```
aws iam generate-credential-report  
# Wait for status: COMPLETE, then download:  
aws iam get-credential-report --query Content --output text | base64 --decode >  
credential_report.csv
```

 AWS limits credential report generation to once every 4 hours. If the report appears stale, wait and retry.

7. Mitigation Using Terraform (IaC)

Use this approach when IAM credentials are managed as Infrastructure as Code. Use the `time_rotating` provider resource to trigger automatic key recreation every 90 days. Requires Terraform 1.2+ and the hashicorp/time provider.

Importing manually created users: If the IAM user was not originally provisioned via Terraform, import it into state before proceeding. `terraform import aws_iam_user.this <USERNAME>`

7.1 Automatic Key Rotation Using Terraform

```
terraform {  
  required_providers {  
    time = { source = "hashicorp/time", version = ">= 0.9" }  
  }  
}  
  
# Rotation trigger - forces key recreation after 90 days  
resource "time_rotating" "access_key_90d" {  
  rotation_days = 90  
}  
  
# Access key is replaced when rotation trigger changes
```

```
resource "aws_iam_access_key" "service_user_key" {
  user      = aws_iam_user.service_user.name
  status    = "Active"
  lifecycle {
    replace_triggered_by = [time_rotating.access_key_90d.id]
  }
}
```

✓ The preferred remediation is to replace access keys with IAM roles. The Terraform rotation above is a fallback for cases where roles are not feasible.

7.2 Recommended Terraform Workflow

1. Wiz identifies the access key older than 90 days
2. Security team validates all consumers of the key before rotating
3. If not in Terraform state, run terraform import
4. Update Terraform to use time_rotating for automated rotation
5. Run terraform plan — review the proposed changes carefully
6. Obtain peer review and approval of the plan output
7. Run terraform apply to enforce the change

8. Mitigation Using CloudFormation (IaC)

Use this approach when IAM credentials are managed via CloudFormation. Option 1 (preferred) is to replace access keys with IAM roles. Option 2 is to manage key lifecycle externally via Secrets Manager rotation.

Drift detection: If credentials were modified manually outside of CloudFormation, the stack's view will be stale. Run drift detection before executing a change set. AWS Console → CloudFormation → Stack → Stack actions → Detect stack drift

8.1 Option 1 — Replace Access Keys with IAM Roles (Preferred)

```
ServiceRole:
  Type: AWS::IAM::Role
  Properties:
    RoleName: service-role
    AssumeRolePolicyDocument:
      Version: '2012-10-17'
      Statement:
```

```
- Effect: Allow
Principal:
Service: ec2.amazonaws.com
Action: sts:AssumeRole
```

8.2 Option 2 — Rotate via Secrets Manager

```
ServiceUser:
  Type: AWS::IAM::User
  Properties:
    UserName: service-user

ServiceUserAccessKey:
  Type: AWS::IAM::AccessKey
  Properties:
    UserName: !Ref ServiceUser
    Status: Active

ServiceUserKeySecret:
  Type: AWS::SecretsManager::Secret
  Properties:
    Name: /iam/service-user/access-key
    SecretString: !Sub |
      {"AccessKeyId":"${ServiceUserAccessKey}",
      "SecretAccessKey":"${ServiceUserAccessKey.SecretAccessKey}"}
```

 Use AWS Secrets Manager rotation or a Lambda + EventBridge 90-day schedule to rotate keys created via CloudFormation. CloudFormation itself does not natively rotate credentials.

8.3 Recommended CloudFormation Workflow

1. Run drift detection on the stack before making any changes
2. Security team validates all consumers of the key before rotating
3. Update template to use IAM roles (preferred) or Secrets Manager rotation
4. Create a change set and review the proposed changes carefully
5. Obtain peer review and approval of the change set
6. Execute the stack update to enforce remediation

9. Document Exception

Use the exception process when a key cannot be rotated within 90 days for a valid, documented business reason (Category A from Section 4.2).

Exception Process: Submit and manage exceptions using the formal exception governance process. All required fields, approval workflows, and expiration timelines are defined there. → [Wiz CSPM Exception Governance](#)

At minimum, every exception must include:

- Business justification for continued use of the key beyond the 90-day rotation threshold
- Approver name and approval date
- Exception expiration date (maximum 90 days — aligned to the rotation threshold)
- Compensating controls in place (e.g., CloudTrail alerting on all key usage, restricted permissions, documented rotation schedule)

10. Detective Control

This section describes how access key age is detected and how to independently verify findings using AWS-native tooling.

10.1 Credential Report — Key Columns

Column	What It Tells You
access_key_1_last_rotated	Date access key 1 was last created or rotated
access_key_2_last_rotated	Date access key 2 was last created or rotated
access_key_1_active	Whether access key 1 is currently enabled (true/false)
access_key_2_active	Whether access key 2 is currently enabled (true/false)

10.2 Generate Credential Report (AWS Console)

1. Log in to the AWS Management Console
2. Go to Services → IAM
3. In the left navigation, click Credential report
4. Click Generate report and wait for status to show Complete
5. Click Download report to save the CSV

 The credential report can only be generated once every 4 hours. If the Generate report button is unavailable or the report appears stale, wait and try again.

10.3 Enable AWS Config Rule

1. Navigate to AWS Config → Rules → Add Rule
2. Search for access-keys-rotated (AWS managed rule)
3. Set maxAccessKeyAge = 90
4. Save and enable the rule

11. Validation and Success Criteria

After completing remediation, verify success using the following checklist before closing the finding.

☐	Re-check the specific resource in Wiz and confirm the finding status is Resolved or No longer applicable.
☐	New access key created and all consumers updated successfully.
☐	CloudTrail confirms the new key is in active use.
☐	Old key deactivated — Inactive status confirmed in IAM console.
☐	7-day monitoring window passed with no service disruption or application errors.
☐	Old key deleted after validation period.
☐	Credential report shows AccessKey1LastRotated date within the last 90 days.
☐	AWS Config rule access-keys-rotated shows Compliant.
☐	Update the Finding Management Tool with the remediation outcome and date.
☐	If an exception was filed (Category A), confirm it is logged with an expiration date.
☐	Update runbook or IaC documentation if any environment-specific steps were required.

12. References

- [Wiz Cloud Configuration Rules](#)
- [AWS Secrets Manager Key Rotation](#)
- [AWS Config Rule — access-keys-rotated](#)
- [AWS IAM Credential Report](#)
- [CSA CCM v4.0.5 Cargill Framework \(Wiz\)](#)
- [Cloud Security Navigator \(CSN\)](#)
- [Master Template – Remediation SOP](#)
- [Wiz CSPM Exception Governance](#)
- [CSPM Finding Management Tool](#)

